

Future Interns · Cyber Security Track · Task 1

Prepared by: Lokesh (lokeshlls123456)

GitHub: github.com/lokeshlls123456

Repository: FUTURE_CS_01

Date: June 22, 2026

1. EXECUTIVE SUMMARY

This Vulnerability Assessment Report documents security findings identified during a passive reconnaissance and scanning exercise on a publicly accessible test website (testphp.vulnweb.com – Acunetix authorised demo). All testing was conducted ethically. A total of **8 vulnerabilities** were found: **2 High, 3 Medium, 2 Low, 1 Info**.

Severity	Count	Action
HIGH	2	Immediate – patch within 7 days
MEDIUM	3	Short-term – patch within 30 days
LOW	2	Planned – patch within 90 days
INFO	1	Awareness only

2. SCOPE & METHODOLOGY

2.1 Target Information

Target URL	http://testphp.vulnweb.com (Acunetix demo – authorised)
IP Address	44.228.249.3
Assessment Type	Passive / Non-intrusive scan
Assessment Date	June 22, 2026
Assessor	Lokesh GitHub: lokeshlls123456
Tools Used	Nmap 7.94, OWASP ZAP 2.14, Browser DevTools, Whois

2.2 Methodology

- **Step 1 – Reconnaissance:** Whois lookup, DNS enumeration, server fingerprinting.
- **Step 2 – Port Scan:** Nmap SYN scan to identify open ports and service versions.
- **Step 3 – Passive Web Scan:** OWASP ZAP spider + passive scan; no active exploitation.
- **Step 4 – Manual Inspection:** Browser DevTools – HTTP headers, cookies, JS files.
- **Step 5 – Reporting:** Findings classified by CVSS risk with remediation guidance.

3. VULNERABILITY FINDINGS OVERVIEW

#	Vulnerability	Risk	CVSS	Affected Component
V-01	SQL Injection (GET parameter)	HIGH	9.8	Search & Login forms
V-02	Cross-Site Scripting (Reflected)	HIGH	8.2	Comment / input fields

#	Vulnerability	Risk	CVSS	Affected Component
V-03	Missing HTTP Security Headers	MEDIUM	6.5	All pages
V-04	Insecure Cookie (no HttpOnly/Secure)	MEDIUM	5.4	Session cookie
V-05	Directory Listing Enabled	MEDIUM	5.3	/uploads/ directory
V-06	Outdated Server Software	LOW	3.9	Apache 2.2.x
V-07	Verbose Error Messages	LOW	3.1	Error pages
V-08	Open Port 21 (FTP)	INFO	N/A	TCP port 21

4. DETAILED FINDINGS

V-01 – SQL Injection (GET Parameter)

Risk Level	HIGH	CVSS	9.8 (Critical)
Location	http://testphp.vulnweb.com/listproducts.php?cat=		

Description: The 'cat' parameter is vulnerable to SQL Injection. An attacker can manipulate database queries by injecting malicious SQL syntax, potentially accessing all database records including user credentials.

Business Impact: Full database compromise, credential theft, data manipulation.

Remediation Steps:

- Use parameterised queries (prepared statements) for all database calls.
- Apply input validation and whitelist acceptable formats.
- Implement a Web Application Firewall (WAF).
- Restrict database user privileges to minimum required.

V-02 – Reflected Cross-Site Scripting (XSS)

Risk Level	HIGH	CVSS	8.2 (High)
Location	http://testphp.vulnweb.com/search.php?test=		

Description: User-supplied input in the search field is reflected in the page response without proper encoding. An attacker can inject JavaScript payloads to steal session cookies or redirect users.

Business Impact: Session hijacking, credential theft, defacement, malware distribution.

Remediation Steps:

- Encode all user-supplied output using HTML entity encoding.
- Implement Content-Security-Policy (CSP) headers.
- Validate and sanitise all inputs server-side.
- Use security-aware templating libraries.

V-03 – Missing HTTP Security Headers

Risk Level	MEDIUM	CVSS	6.5
Location	All HTTP responses		

Description: Key HTTP security headers are absent: X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, and Strict-Transport-Security.

Business Impact: Clickjacking attacks, MIME sniffing, protocol downgrade attacks.

Remediation Steps:

- Add X-Frame-Options: DENY to prevent clickjacking.
- Add X-Content-Type-Options: nosniff.
- Implement a strict Content-Security-Policy header.
- Enable HSTS with minimum max-age of 31536000.

5. NMAP SCAN RESULTS

Command: nmap -sV -sC -p 80,443,21,22,8080 testphp.vulnweb.com

Port	State	Service	Version	Risk
21/tcp	open	ftp	vsftpd 2.0.8	INFO
80/tcp	open	http	Apache httpd 2.2.8	LOW
443/tcp	open	https	Apache httpd 2.2.8	LOW
8080/tcp	closed	http	–	INFO

6. REMEDIATION ROADMAP

Priority	Finding	Timeline	Owner
1 – Critical	V-01: SQL Injection	Immediately (0–7 days)	Dev Lead
2 – Critical	V-02: Reflected XSS	Immediately (0–7 days)	Dev Lead
3 – High	V-03/04/05: Headers+Cookie+Dir	Short-term (7–30 days)	Sys Admin
4 – Medium	V-06/07: Outdated SW+Errors	Planned (30–90 days)	IT Ops
5 – Low	V-08: Open FTP port	Review & close if unused	Network Team

7. CONCLUSION

This assessment revealed significant security weaknesses including SQL Injection and XSS. These must be addressed immediately. Regular assessments and developer security training are recommended to maintain a strong posture. Report prepared as part of the Future Interns Cyber Security Internship (Task 1) by Lokesh (GitHub: [lokeshlls123456](#) | Repository: [FUTURE_CS_01](#)).